

第一部分：判断题（1-30题）

1. 部署入侵防御系统（IPS）可以完全保证网络不受任何攻击。

答案：错误

解析：没有任何安全系统能提供100%的保证。IPS可以主动阻断已知和部分未知攻击，但无法防御所有攻击，特别是高级持续性威胁（APT）和零日漏洞攻击。网络安全需要多层次、纵深防御。

2. 基于特征的检测技术对未知攻击和零日漏洞攻击通常无效。

答案：正确

解析：基于特征（误用检测）依赖于已知攻击的签名/模式库，因此无法识别不在库中的新攻击（零日攻击）。

3. 基于网络的入侵检测系统（NIDS）可以检测到网络内部主机上的所有恶意活动。

答案：错误

解析：NIDS通过监控网络流量检测攻击，如果恶意活动不产生网络流量（如本地提权、物理接触攻击），或者流量被加密而NIDS无法解密分析，则无法检测。

4. 入侵检测系统中的“漏报”是指攻击发生了，但系统没有产生警报。

答案：正确

解析：这是“漏报”（False Negative, FN）的标准定义。

5. 由于IDS采用旁路部署，因此其本身不会影响网络性能。

答案：错误

解析：IDS旁路部署不直接处理转发流量，因此通常不会成为网络瓶颈。但其数据采集（如端口镜像）可能对源交换机性能有轻微影响，且分析处理能力不足可能丢包，间接影响监控效果。

6. 入侵防御系统（IPS）是入侵检测系统（IDS）的完全替代品，部署了IPS后就不再需要IDS。

答案：错误

解析：IPS和IDS是互补关系。IPS串联部署可能因误报阻断正常业务，因此常同时部署旁路IDS用于监控、审计和验证IPS规则，避免误阻断。

7. 基于误用检测的IDS可以有效检测出未知的攻击和变种攻击。

答案：错误

解析：误用检测（特征检测）恰恰无法有效检测未知攻击和显著变种。

8. HIDS（基于主机的入侵检测系统）可以监测到对主机的文件系统进行篡改的行为。

答案：正确

解析：HIDS通过监控文件完整性（如关键系统文件、配置文件的哈希值变化）来检测此类行为。

9. 入侵检测系统中的“误报”是指系统未能识别出真正的攻击行为。

答案：错误

解析：描述的是“漏报”。“误报”（False Positive, FP）是指将正常、合法的行为误判为攻击并产生警报。

10. IPS以串联方式部署在网络中，因此可能会引入网络延迟成为单点故障。

答案：正确

解析：串联部署是IPS的工作机制，确实会引入处理延迟，并且如果设备故障，可能导致网络中断。高可用性（HA）部署可以缓解此问题。

11. 在入侵检测中，“误报”是指系统未能检测到真实发生的入侵行为。

答案：错误

解析：同第9题，这是“漏报”的定义。

12. 部署为内联模式的入侵防御系统（IPS）可能会因为误判而影响正常的网络通信。

答案：正确

解析：这正是IPS的主要风险之一。如果规则过于敏感或存在缺陷，可能将合法流量误判为攻击并进行阻断。

13. 对于一种从未被记录过的新型攻击（零日攻击），基于签名的入侵检测系统可以有效识别。

答案：错误

解析：基于签名（即误用检测）的系统无法识别零日攻击。

14. 分布式拒绝服务攻击（DDoS）产生的大量异常流量，容易被网络入侵检测系统（NIDS）发现。

答案：正确

解析：NIDS通过分析网络流量模式，擅长发现DDoS、端口扫描等网络层攻击。

15. 入侵检测系统（IDS）可以完全替代防火墙，提供所有的网络安全防护。

答案：错误

解析：IDS和防火墙功能不同。防火墙主要进行访问控制（允许/拒绝），IDS主要进行检测和报警。两者是互补关系，不能相互替代。

16. 防火墙的主要功能是访问控制，而IDS/IPS的主要功能是检测与响应入侵行为。

答案：正确

解析：这是防火墙和IDS/IPS的基本功能定位。

17. 蜜罐系统通过模拟虚假服务来吸引攻击者，从而保护真实的生产系统。

答案：正确

解析：蜜罐是诱饵系统，旨在吸引攻击以研究攻击手法、收集情报，并转移攻击者对真实系统的注意力。

18. 一个优秀的IDS应该追求100%的检测率，即使误报率很高也可以接受。

答案：错误

解析：误报率过高会导致警报泛滥，使安全人员疲劳并可能忽略真实攻击。优秀的IDS需要在检测率（Recall）和精确度（Precision，与误报率相关）之间取得平衡。

19. 安全信息和事件管理（SIEM）系统可以聚合来自不同安全设备（如IDS、防火墙）的日志。

答案：正确

解析：SIEM的核心功能之一是集中收集、归一化和存储来自各种安全设备、系统、应用的日志和事件数据。

20. 在异常检测中，建立正常行为基线是一个必要的步骤。

答案：正确

解析：异常检测通过建立正常行为基线，然后将当前行为与基线比较，发现显著偏差来识别潜在攻击。

21. 状态包检测防火墙本身就具备了完整的入侵检测能力。

答案：错误

解析：状态包检测防火墙主要跟踪连接状态，进行基于状态（如TCP握手）的访问控制。它不具备深入的入侵检测能力（如应用层攻击检测），后者需要深度包检测（DPI）或特征匹配等技术。

22. 蜜罐技术通过模拟一个有价值的、存在漏洞的系统来吸引攻击者，从而保护真实的系统。

答案：正确

解析：同第17题。

23. 在评估IDS时，检测率越高，说明系统的性能越好，无需关心误报率。

答案：错误

解析：同第18题，需综合考虑检测率和误报率（或精确度）。高检测率伴随高误报率会降低系统可用性。

24. 基于异常的检测技术需要首先建立系统或用户的正常行为模式基线。

答案：正确

解析：同第20题。

25. SIEM（安全信息和事件管理）主要功能是替代网络中的IDS和IPS，实现统一的防御。

答案：错误

解析：SIEM是集中分析和管理的平台，用于聚合、关联分析和可视化安全事件，不替代底层的安全防护设备（防火墙、IDS/IPS等）。

26. 入侵检测系统（IDS）的主要功能是主动拦截并阻止恶意网络攻击。

答案：错误

解析：IDS的主要功能是检测和报警。主动拦截和阻止是入侵防御系统（IPS）的功能。

27. 基于异常的入侵检测方法通过比对已知攻击特征的数据库来识别威胁。

答案：错误

解析：描述的是基于特征（误用检测）的方法。基于异常的检测是通过与正常行为基线比较来发现偏差。

28. 著名的开源安全工具Snort是一种网络入侵检测系统（NIDS）。

答案：正确

解析：Snort是一款广泛使用的开源网络入侵检测/防御系统（NIDS/NIPS），主要用于网络流量分析。

29. 主机入侵检测系统（HIDS）通常部署在网络边界，用于监控所有进出网络的流量。

答案：错误

解析：HIDS部署在单个主机（服务器或终端）上，监控该主机内部的活动（如日志、文件、进程）。监控网络边界流量是NIDS的任务。

30. 入侵防御系统（IPS）必须具备实时阻断检测到的攻击的能力。

答案：正确

解析：实时阻断（或响应）是IPS区别于IDS的核心能力。

第二部分：后续判断题

31. 数据库管理员拥有数据库的一切权限。

答案：错误

解析：数据库管理员（DBA）通常拥有高级权限，但并非“一切”。在安全要求高的环境中，权限可能被细分（如安全管理员、审计员），且DBA权限可能受到操作系统、网络安全策略等制约。

32. 公钥密码体制有两种基本的模型：一种是加密模型，另一种是认证模型。

答案：正确

解析：公钥密码可用于**加密**（用公钥加密，私钥解密）和**认证/签名**（用私钥签名，公钥验证）。

33. 数据越重要，容灾等级越高。

答案：正确

解析：容灾等级（如RTO、RPO）根据数据价值、业务连续性要求确定，数据越关键，要求的恢复时间越短，数据丢失越少，容灾等级越高。

34. 机房供电线路和动力、照明用电可以用同一线路。

答案：错误

解析：机房供电要求高可靠性，通常要求独立线路，动力（如空调、UPS）和照明应分开，避免相互干扰。

35. 屏蔽室的拼接、焊接工艺对电磁防护没有影响。

答案：错误

解析：屏蔽室的电磁屏蔽效能（SE）高度依赖于拼接、焊接的连续性和质量，工艺不好会导致电磁泄漏。

36. 容灾项目的实施过程是周而复始的。

答案：正确

解析：容灾是持续过程，包括需求分析、方案设计、实施、测试、维护和定期演练，需不断更新以适应业务变化。

37. 解决共享文件夹的安全隐患应该卸载Microsoft网络的文件和打印机共享。

答案：错误

解析：卸载服务可消除隐患，但也会禁用共享功能。更合理的做法是加强共享权限设置、启用强密码、使用网络访问控制（NAC）等安全措施。

38. 机房内的环境对粉尘含量没有要求。

答案：错误

解析：机房对粉尘含量有严格要求，粉尘过多会损害设备（如堵塞风扇、引起静电、加速元器件老化）。

39. 按计算机病毒的传播媒介来分类，可分为单机病毒和网络病毒。

答案：正确

解析：单机病毒通过移动存储等传播，网络病毒通过网络（如邮件、网页、漏洞）传播。

40. 复合型防火墙是内部网与外部网的隔离点，起着监视和隔绝应用层通信流的作用，同时也常结合过滤器的功能。

答案：正确

解析：复合型防火墙（如下一代防火墙NGFW）集成了传统防火墙、入侵防御、应用识别与控制等功能，可在应用层进行深度检测和过滤。

41. 解决共享文件夹的安全隐患应该卸载Microsoft网络的文件和打印机共享。

答案：错误

解析：同第37题。

42. 数据备份按数据类型划分可以分成系统数据备份和用户数据备份。

答案：正确

解析：系统数据（如操作系统、应用程序）和用户数据（业务数据、个人文件）备份策略和重要性不同，常分开处理。

43. 常见的操作系统包括 DOS、OS/2、UNIX、XENIX、LinukWindows、Netware、Oracle 等。

答案：错误

解析：Oracle是数据库软件，不是操作系统。“LinukWindows”应为“Linux、Windows”。

44. 如果向某个组分配了权限，则作为该组成员的用户也具有这一权限 OA
例如，如果Backup Operators 组有此权限，而 his 又是该组成员，则 his 也有此权限。

答案：正确

解析：这是Windows等系统中组权限继承的基本原理。

45. 计算机场地在正常情况下温度保持在 18~28 摄氏度。

答案：正确

解析：这是机房温度的常见推荐范围（如GB 50174标准）。

46. 灾难恢复和容灾具有不同的含义。

答案：正确

解析：容灾（Disaster Recovery）强调在灾难发生时保持业务连续（不中断或快速切换），灾难恢复（Disaster Recovery）强调灾难发生后恢复到正常状态的过程。两者紧密相关但侧重点不同。

47. 数据库安全只依靠技术即可保障。

答案：错误

解析：数据库安全需要技术（如加密、访问控制、审计）、管理（如制度、流程、人员培训）和法律/合规共同保障。

48. 事务具有原子性，其中包括的诸多操作要么全做，要么全不做。

答案：正确

解析：原子性是事务的ACID属性之一。

49. 防火墙规则集的内容决定了防火墙的真正功能。

答案：正确

解析：防火墙的行为完全由其规则集定义，规则集的质量决定了安全策略的有效性。

50. 隔离网闸两端的网络之间不存在物理连接。

答案：正确

解析：隔离网闸（GAP）通过专用硬件和协议，以“摆渡”方式（如电子开关、光信号）在断开物理连接的两个网络间交换数据，确保物理隔离。

51. QQ 是与朋友联机聊天的好工具，不必担心病毒。

答案：错误

解析：任何软件都可能存在漏洞，QQ历史上曾出现安全漏洞和通过QQ传播的病毒/木马。需保持软件更新和安全意识。

52. 校验和技术只能检测已知的计算机病毒。

答案：错误

解析：校验和技术（如文件完整性检查）通过计算文件的哈希值与基准值比较，可检测文件是否被任何修改（包括未知病毒），但不能识别病毒类型。它主要用于检测变化，而非特定病毒。

53. 备用电路板或者元器件、图纸文件必须存放在防静电屏蔽袋内，使用时要远离静电敏感器件。

答案：正确

解析：这是电子元器件静电防护（ESD）的基本要求。

54. 贝叶斯过滤技术具有自适应、自学习的能力，目前已经得到了广泛的应用。

答案：正确

解析：贝叶斯过滤（如用于垃圾邮件过滤）通过学习用户标记更新概率模型，具有自适应能力。

55. 主动响应和被动响应是相互对立的，不能同时采用。

答案：错误

解析：主动响应（如阻断连接）和被动响应（如记录日志、报警）可以结合使用。例如，IDS可配置为报警同时联动防火墙进行阻断（主动）。

56. MS SQL Server 与 Sybase SQL Server 的身份认证机制基本相同。

答案：正确

解析：MS SQL Server早期版本源于Sybase SQL Server，因此认证机制（如混合模式：Windows认证和SQL Server认证）相似。

57. 即使在企业环境中，个人防火墙作为企业纵深防御的一部分也是十分必要的。

答案：正确

解析：个人防火墙（主机防火墙）作为终端防护的一层，可控制本机网络访问，是纵深防御的重要组成部分。

58. 基于主机的漏洞扫描不需要有主机的管理员权限。

答案：错误

解析：基于主机的漏洞扫描（如检查系统配置、补丁、弱口令）通常需要管理员（root/Administrator）权限才能全面访问系统信息。

59. 在安全模式下木马程序不能启动。

答案：错误

解析：安全模式只加载基本驱动和服务，但某些木马/病毒可能通过修改注册表、驱动等方式在安全模式下启动。并非所有恶意软件都能被安全模式阻止。

60. 计算机病毒的传播离不开人的参与，遵循一定的准则就可以避免感染病毒。

答案：错误

解析：病毒可通过网络漏洞、恶意脚本等自动传播，无需用户直接操作（如“路过式下载”）。即使遵循安全准则（如不打开陌生邮件），仍可能因系统或软件漏洞而感染。

第三部分：填空题

1. 入侵检测的两种基本分析技术是误用检测和（**异常检测**）。
2. IDS的三种典型部署模式是基于网络，基于主机和（**混合型/分布式**）。
3. 在性能评估中，检测率 = $TP / ((TP) + FN)$ 。（用TP，FN等表示）。
4. 一个典型的Snort规则包含规则头和（**规则选项**）两个部分。
5. 根据检测对象的不同，入侵检测系统主要分为基于（**网络**）的IDS和基于主机的IDS。
6. 入侵检测系统（IDS）的核心功能是监控和检测，而入侵防御系统（IPS）则在此基础上增加了主动（**阻断**）的能力。
7. 根据检测数据来源的不同，入侵检测系统主要可分为基于（**主机**）的入侵检测系统（HIDS）和基于网络的入侵检测系统（NIDS）。
8. 入侵检测的两种主要技术方法是误用检测（依赖于已知攻击特征库）和（**异常**）检测（通过建立正常行为基线来发现异常）。
9. 入侵检测的两种基本分析模型是（**误用**）检测和异常检测。
10. IDS的三种主要数据源是（**主机数据源、网络数据源、应用程序日志**）。（注：答案不唯一，常见表述包括：操作系统日志、网络数据包、应用日志等）
11. 在网络安全中，（**拒绝服务/DOS**）攻击是指试图耗尽目标系统资源，使其无法提供正常服务。
12. 一个完整的入侵检测过程通常包括信息收集、（**分析**）和响应三个阶段。
13. 在入侵检测评估中，检测率 = $(TP) / (\text{攻击总数})$ 。（用TP，FN等表示）
14. 一个完整的Snort规则主要由规则头和（**规则选项**）两部分组成。
15. 除了基于网络和基于主机，入侵检测系统还可以根据分析数据的来源分为基于（**协议**）和基于应用的IDS。